

G-CAF

GovDigital Composable Architecture Framework

Volume 16

Policy Framework & Training

v2.0

Table of Contents

Chapter 1 Policy Framework Overview

3-tier policy hierarchy: Organizational Policies → Architecture Principles → Contracts

Chapter 2 Data Governance Policy — 7 Principles

DATPOL-001 through DATPOL-007 with G-CAF mapping

Chapter 3 Data Policy Integration & Quick Reference

Tier 1→2→3 mapping, metrics, quick reference card

Chapter 4 Security Policy — 7 Principles

SECPOL-001 through SECPOL-007 with G-CAF mapping

Chapter 5 Security Policy Integration & Quick Reference

Tier 1→2→3 mapping, gateway validation, quick reference card

Chapter 6 G-CAF Training Guide (v2.0)

7 modules, 80 minutes: 3T+2F model, folder structure, real projects

Chapter 7 AI Security Training Guide

Common foundation + 4 role-based tracks (Developer, Architect, SOC, Executive)

Chapter 8 PBC Identification Workshop Guide

2–3 day facilitation guide with participant roles and outputs

Chapter 9 Critical Enablers

4 prerequisites: IDP Automation, Schema Registry, Catalog DARCI, Funding Model

Chapter 10 Composition Governance

Experience registration, security assessment levels, UX bypass prevention

Chapter 1

Policy Framework Overview

G-CAF integrates organizational policies through a 3-tier hierarchy ensuring strategic policy intent flows through architecture principles into enforceable contracts.

Tier	Content	Owner	Validation
Tier 1: Organizational Policies	17 Policies + 7 Data policy principles	CISO / CDO	Annual policy review
Tier 2: Architecture Principles	17 G-CAF principles (ARC-001–ARC-017)	EA Office	Gateway checkpoints
Tier 3: Contracts	Security, Data, Integration, NFR, Operational contracts	Domain owners	PBC-specific compliance

Tier 1 establishes WHAT must be protected (organizational policy). Tier 2 defines HOW architecture implements policy (principles). Tier 3 specifies WHAT EXACTLY each PBC must do (contracts with measurable requirements).

Chapter 2

Data Governance Policy — 7 Principles

ID	Principle	Statement	G-CAF Mapping
DATPOL-001	Ownership & Accountability	Every data asset has a single accountable owner	Data Contract, Data Ownership Governance
DATPOL-002	Transparency & Discoverability	All data described with standardized metadata	Data Catalog, Metadata Manager, ARC-008
DATPOL-003	Quality by Design	Quality built in, measured, continuous improvement	Quality Contract, Quality Engine, ARC-015
DATPOL-004	Access & Privacy	Access controlled with full accountability	ARC-004 Privacy, ARC-005 Zero Trust, Security Contract
DATPOL-005	Sharing & Interoperability	Standardized sharing for Whole-of-Government	GovX, Data Contract, Integration Contract
DATPOL-006	Federated Governance	Entity ownership with central standards	Operational Models, ARB/DDA
DATPOL-007	Maturity & Evolution	Continuous capability improvement	PBC Maturity Model, Gateways, Metrics

Consolidated from 9 original principles. "Secure-by-Design" absorbed by ARC-003 (already an architecture principle).

Chapter 3

Data Policy Integration & Quick Reference

Metric	Value
Original Data Principles	9
Consolidated Policy Principles	7
G-CAF Architecture Principles Used	5 (ARC-004, ARC-005, ARC-008, ARC-009, ARC-015)
G-CAF Contracts Involved	2 (Data Contract, Integration Contract)
Reference Architecture PBCs	15+ data-related PBCs in GovData Platform

Each DATPOL principle traces from policy statement → architecture principle → contract requirements → gateway validation → assessment criteria → reference architecture PBCs.

Chapter 4

Security Policy — 7 Principles

ID	Principle	Statement	G-CAF Mapping
SECPOL-001	Information Protection	Protect CIA of information assets	ARC-003 Security by Design, ARC-010 Design for Failure
SECPOL-002	Privacy & Compliance	Protect personal data per laws and regulations	ARC-004 Privacy by Design, Data Contract
SECPOL-003	Access Control	Least privilege + need to know + access control	ARC-005 Zero Trust, Security Contract
SECPOL-004	Risk-Based Approach	Controls proportional to assessed risk	Criticality Tiers, SAL Levels
SECPOL-005	Defense in Depth	Multiple layers: administrative + technical + physical	Bricks + Mortar, Zero Trust Zones
SECPOL-006	Resilience & Continuity	Withstand, respond, recover + fail safe	ARC-010, Operations Contract, BD-006
SECPOL-007	Shared Responsibility	Management + staff + external + internal	Operational Models, RACI, Cross-Entity SLA

Consolidated from 19 original principles into 7 policy-level principles.

Chapter 5

Security Policy Integration & Quick Reference

Metric	Value
Original Security Principles	19
Consolidated Policy Principles	7
G-CAF Architecture Principles Used	6 (ARC-003, ARC-004, ARC-005, ARC-010, ARC-016, ARC-017)
G-CAF Contracts Involved	3 (Security, Data, Operations)
Gateways with Security Validation	3 (Design, Go-Live, Retirement)

CIA Triad as foundation: Confidentiality (protected from unauthorized disclosure), Integrity (accurate and protected from modification), Availability (accessible when required). Each maps through the 3-tier hierarchy to specific PBC requirements.

Chapter 6

G-CAF Training Guide (v2.0)

80-minute training covering 7 modules for architects, tech leads, developers, procurement, security, and operations.

Module	Topic	Duration	Learning Objectives
1	Understanding the Model	15 min	3T+2F model; visual architecture; tier responsibilities
2	Navigating the Vault	10 min	Folder structure; finding modules; cross-references
3	What Changed in v2.0	10 min	3T+2F vs. 8 layers; Agent PBC type; Operational Excellence principles
4	PBC Lifecycle	15 min	Gateway process; classification; catalog registration
5	Contracts & Compliance	10 min	5 standard contracts; version declaration; schema evolution
6	Third-Party Security	10 min	Vendor compliance; TPSP awareness; certification tiers
7	AI Security Awareness	10 min	AI threat landscape; AIBOM; when to engage AI security team

Chapter 7

AI Security Training Guide

90-minute training: 30-minute common foundation + 4 role-based tracks (20–30 min each). Prerequisite: Modules 1–3 of core training.

Common Foundation (30 min)

AI threat landscape (data poisoning, model theft, adversarial attacks, prompt injection), AI attack surface (training data, model itself, inference pipeline, supply chain), G-CAF AI security contracts overview, and when to engage the AI security team.

Role-Based Tracks

Track	Audience	Duration	Focus
Developer Track	AI/ML Engineers, Data Scientists	30 min	Secure ML pipelines, AIBOM generation, adversarial testing, input validation
Architect Track	Solution/Enterprise Architects	25 min	AI threat modeling, maturity assessment, contract selection, gateway protection
SOC Track	SOC Analysts, Incident Responders	25 min	AI incident taxonomy, detection patterns, forensics procedures, escalation
Executive Track	CISOs, CIOs, Tech Leaders	20 min	AI risk landscape, organizational posture, investment priorities, compliance

Chapter 8

PBC Identification Workshop Guide

Aspect	Specification
Duration	2–3 days (can be split across sessions)
Participants	8–15 people (balanced business + IT)
Outputs	PBC candidate list, ownership assignments, dependency map
Prerequisites	Application landscape, capability maps, org charts, process docs

Participant Roles

Role	Purpose	Count
Business domain experts	Know the processes	3–4
Product owners	Know the priorities	2–3
Enterprise architects	Know the systems	2–3
Development leads	Know the constraints	2–3
Operations/DevOps	Know the runtime	1–2

Workshop outputs feed directly into the Initiation Gateway submission. Materials needed: large wall/virtual whiteboard, sticky notes, capability mapping templates, bounded context canvas, timer for timeboxing.

Chapter 9

Critical Enablers

Prerequisites that must be operational before G-CAF governance can function effectively. Without these, governance becomes manual bureaucracy.

Enabler	Why Critical	Required By
IDP Automation Live	Without pipeline enforcement, Catalog registration bottlenecked	Phase 0 (Months 0-3) annual
GovDX Schema Registry BSL	Schema compatibility must be enforced at publish time; otherwise, NS Data Verification Transparency fails	Phase 1 (Months 3-6)
Catalog DARCI Defined	Clear ownership for Catalog updates and dispute resolution prevents governance paralysis	Phase 0 (Months 0-3)
Shared PBC Funding Model	Entities need cost visibility; without it, shared service adoption blocked by budget uncertainty	Phase 0 (Months 0-3)

Chapter 10

Composition Governance

Security Assessment by Composition Level

Level	Security Review	Data Exposure	Approver	SLA
Enterprise	Full DDA + pen testing	All data flows mapped and approved	DDA	10 working days
Entity	DDA lightweight + auto SAS/DAST	Static data exposure checklist signed	DDA (light)	5 working days
Team	Automated scanning only	Pre-approved PBC palette enforced	Auto-DDA notification	2 working days
Self-Service	Guardrails enforce; no custom code	Read-only access to approved data sets	Auto-guardrails	Immediate

UX Layer Bypass Prevention Rules

Rule	Enforcement
Active PBCs Only	Compositions may only consume PBCs with 'Active' status in Catalog
No Direct DB Access	Direct database access from Experience layer is PROHIBITED
Interface Contract Traversal	All data access must traverse PBC Interface Contracts via GovDX
API Routing Enforcement	Composition Platform must enforce PBC API routing (no bypass paths)
Quarterly Audit	Quarterly audit of Experience-to-data access paths